PDF Tool — Work Session Log

Complete record of the audit, fixes, and infrastructure work · 13–14 July 2026

Repo: github.com/mukeshroyhub/pdf_tool · Live: pdftool-web.onrender.com

1. What was done (in order)

Full 15-phase audit of the repo, live app, and Render deployment. Result: strong code, but critical operational gaps. Production readiness assessed at ~60%. Detailed findings in AUDIT-REPORT.md.

Six security fixes — implemented, tested (72 tests passing), and deployed:

- **S1 Guest isolation** — each guest gets a unique throwaway account (100 MB quota) with 24 h auto-cleanup; old shared guest account deleted.
- **S2** — multer upgraded 1.x → 2.x (DoS CVEs).
- **S3** — magic-byte upload validation (lib/sniff.ts): files whose bytes don't match their declared type are rejected.
- **S6** — security headers added to the web app (HSTS, CSP, Permissions-Policy).
- **S7** — scheduled token purge (boot + every 12 h; revoked tokens kept 7 days for reuse detection).
- **S4** — SMTP + Google OAuth env slots added to render.yaml (values set in dashboard; email not yet configured).

Fixed two deploy-breaking bugs found along the way: the Windows-generated lockfile omitted Linux native binaries (Dockerfiles now install fresh), and render.yaml pointed at the wrong API URL (corrected to pdftool-api-xyd5.onrender.com).

Database migrated off the expiring Render free Postgres to **Neon** (free, no expiry). Data copied via scripts/migrate-to-neon.mjs (3 users, 16 sessions, 1 file, 9 activities). Sign-in verified.

Durable file storage → **Supabase** (S3-compatible). storage.ts refactored into a driver interface (local disk + S3/R2). Uploads now survive restarts — previously lost on every deploy/sleep because Render's free disk is ephemeral. Verified live.

GitHub Actions CI (.github/workflows/ci.yml): every push runs install → prisma generate → typecheck → lint (advisory) → test → build.

2. Current live configuration

Neon — PostgreSQL (free, no expiry); DATABASE_URL set on the Render pdftool-api service.

Supabase — object storage bucket **pdfforge-files**. Render pdftool-api env vars:

```
STORAGE_DRIVER=s3 · S3_BUCKET=pdfforge-files · S3_REGION=us-east-1 ·
S3_FORCE_PATH_STYLE=true
S3_ENDPOINT=https://cpseztzafaclmfmdtwsy.storage.supabase.co/storage/v1/s3
S3_ACCESS_KEY_ID / S3_SECRET_ACCESS_KEY (secret, in dashboard)
```

Render — two free Docker services (pdftool-api, pdftool-web) + the old pdftool-db (now unused). Free tier sleeps after 15 min idle, so the first request after idle takes ~30–60 s (the 502s seen were cold starts, not failures).

3. Outstanding items — YOU need to do these

- **Revoke the GitHub tokens** — two were pasted in chat. Settings → Developer settings → Fine-grained tokens → delete. Pushes now use the browser sign-in already set up.

- **Rotate the Neon DB password** — it appeared in a screenshot. Neon → project → Roles → reset → update DATABASE_URL on Render.
- **Confirm the CI run is green** on the Actions tab (last fix: remove Windows lockfile before install).
- *Optional:* delete the old pdftool-db on Render once you trust Neon.

4. Roadmap — not yet done

Should have: SMTP (free Brevo/Resend) for real email verification; password protect / unlock PDFs (qpdf); e-signatures (draw/type/upload); Prisma migrations instead of db push on boot.

Nice to have: dark mode; tool-grid dashboard; branded 404; page numbers / headers-footers; crop; metadata editor; ZIP download; flatten; compiled API build; response compression + request logging.

5. Helper scripts & how to work on this project

- scripts/delete-old-guest.mjs — removed the legacy shared guest account (done).
- scripts/migrate-to-neon.mjs — copied data Render → Neon (done; re-runnable).

Always run commands from the project root, then use the standard workflow:

```
cd "C:\Users\TEI-1420\Downloads\pdf tool\pdfforge"
npm install # after pulling changes
npm test # run the API test suite (72 tests)
git add -A && git commit -m "..." && git push # deploys via Render + runs CI
```

Generated 14 Jul 2026 · companion to AUDIT-REPORT.md